

Threat Modeling Report

Created on 7/2/2026 3:28:16 PM

Threat Model Name: Encryptix

Owner: Poorva Vaishnav

Reviewer:

Contributors:

Description: Encryptix is a secure web-based file sharing application that performs client side encryption before the files are uploaded to Google Drive. Users authenticates using OAuth 2.0. The Encryptix frontend handles user interactions and client side encryption/decryption, while the FastAPI backend manages the authentication, Google Drive integration, share link generation and Gmail integration. All communications between components and external Google services occurs over HTTPS to ensure confidentiality and integrity.

Assumptions:

External Dependencies:

Threat Model Summary:

Not Started	0
Not Applicable	35
Needs Investigation	5
Mitigation Implemented	20
Total	60
Total Migrated	0

Diagram: Diagram 1

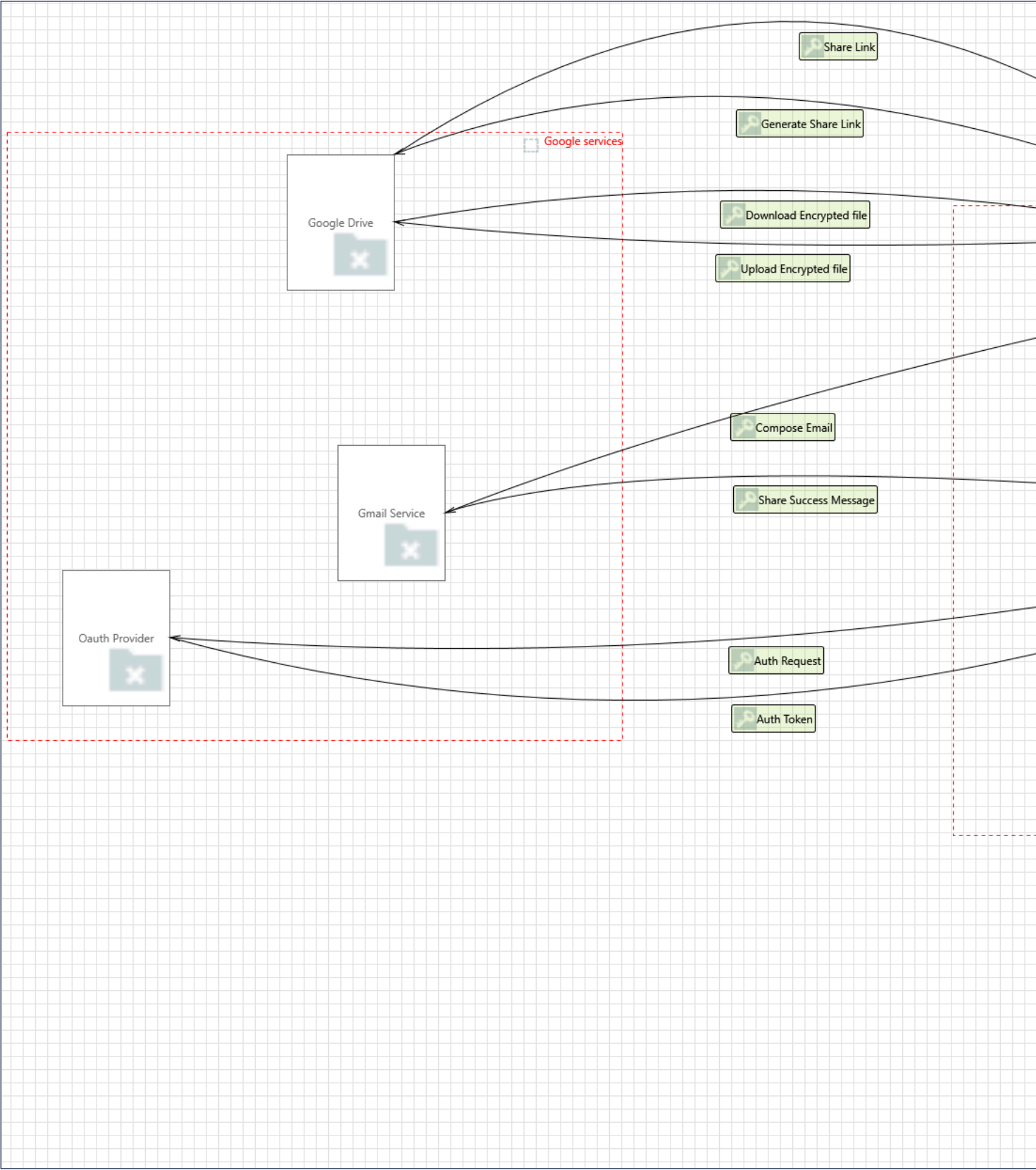
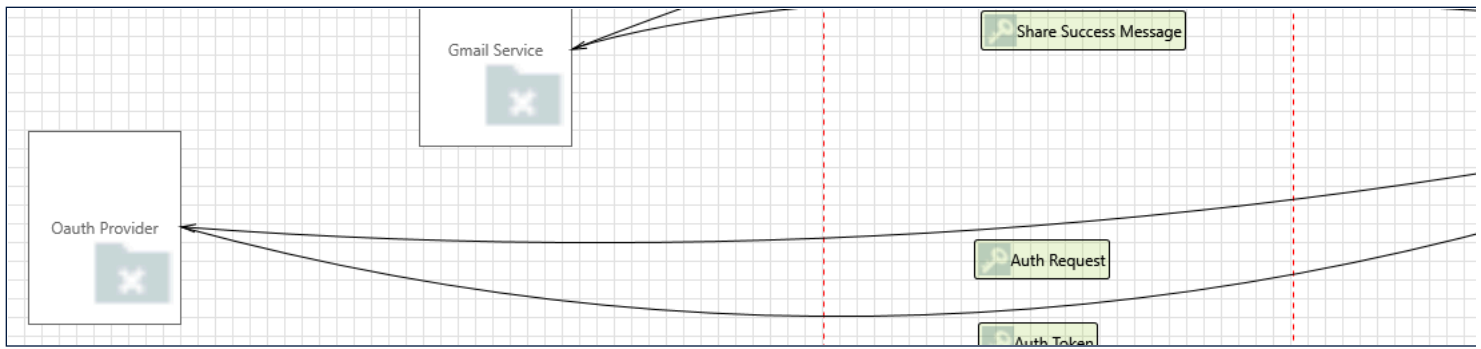


Diagram 1 Diagram Summary:

Not Started	0
Not Applicable	35
Needs Investigation	5
Mitigation Implemented	20
Total	60
Total Migrated	0

Interaction: Auth Request



1. Data Flow Auth Request Is Potentially Interrupted [State: Needs Investigation] [Priority: Medium]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: To Prevent DoS, some proposed mitigations not applied in the system are :

- Enable rate limiting and throttling for FastAPI endpoints
- graceful error handling
- Use Request timeouts for Google's OAuth endpoints

2. External Entity OAuth Provider Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: Medium]

Category: Repudiation

Description: OAuth Provider claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Here the Google cloud console has been used as the OAuth provider, So the in built logging process is already in use

3. Spoofing of the OAuth Provider External Destination Entity [State: Mitigation Implemented] [Priority: High]

Category: Spoofing

Description: OAuth Provider may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of OAuth Provider. Consider using a standard authentication mechanism to identify the external entity.

Justification: Since HTTPS /TLS and Google OAuth 2.0 are implemented already, this threat can be considered mitigated.

Interaction: Auth Token



4. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: ENCRYPTIX Web Frontend may be able to impersonate the context of OAuth Provider in order to gain additional privilege.

Justification: The OAuth Provider (Google) independently authenticates users and issues cryptographically signed tokens that are verified by the application. The frontend does not have the ability to generate or sign valid OAuth responses or tokens, and therefore cannot impersonate the OAuth Provider. As a result, elevation of privilege through impersonation of the OAuth Provider is not applicable.

5. Potential Process Crash or Stop for ENCRYPTIX Web Frontend [State: Needs Investigation] [Priority: Medium]

Category: Denial Of Service

Description: ENCRYPTIX Web Frontend crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: The Web Frontend relies on communication with the OAuth Provider over a network to perform authentication and receive tokens or authorization responses. Failures such as network instability, delayed OAuth responses, large authentication payloads, or improper handling of asynchronous authentication flows can cause the frontend to become unresponsive, slow, or fail to complete authentication, leading to availability issues.

Proposed Mitigations:

- Implement timeout and retry handling for OAuth requests
- Optimize OAuth flow handling (async processing, state management)
- Provide fallback/error UI for authentication failures and Handle failed or delayed authentication responses gracefully
- Monitor authentication latency and errors

6. Potential Data Repudiation by ENCRYPTIX Web Frontend [State: Mitigation Implemented] [Priority: Medium]

Category: Repudiation

Description: ENCRYPTIX Web Frontend claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: Google Cloud Console is used as the OAuth provider. Hence logging is already taken care for.

7. Elevation by Changing the Execution Flow in ENCRYPTIX Web Frontend [State: Needs Investigation] [Priority: High]

Category: Elevation Of Privilege

Description: An attacker may pass data into ENCRYPTIX Web Frontend in order to change the flow of program execution within ENCRYPTIX Web Frontend to the attacker's choosing.

Justification: The ENCRYPTIX Web Frontend processes authentication data received from the OAuth Provider, such as tokens and user information, and uses this data to control application behavior. Although the data is securely transmitted and cryptographically signed by the OAuth Provider, improper validation or handling of this input within the frontend may allow attacker-controlled or unexpected values to influence execution flow. Following mitigations can be followed:

- Validate and sanitize all token data before use
- Avoid directly injecting token/user data into UI
- Implement proper token verification (issuer, audience, expiry)
- Use safe frontend frameworks and encoding practices

8. ENCRYPTIX Web Frontend May be Subject to Elevation of Privilege Using Remote Code Execution [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: OAuth Provider may be able to remotely execute code for ENCRYPTIX Web Frontend.

Justification: The OAuth Provider communicates with the Web Frontend by returning structured authentication data such as authorization codes or tokens, which are securely transmitted and cryptographically signed. The provider does not send executable code or influence frontend execution logic. Therefore, remote code execution by the OAuth Provider is not applicable.

9. Data Flow Auth Token Is Potentially Interrupted [State: Needs Investigation] [Priority: Medium]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: To Prevent DoS, some proposed mitigations not applied in the system are :

- Enable rate limiting and throttling for FastAPI endpoints
- graceful error handling
- Use Request timeouts for Google's OAuth endpoints

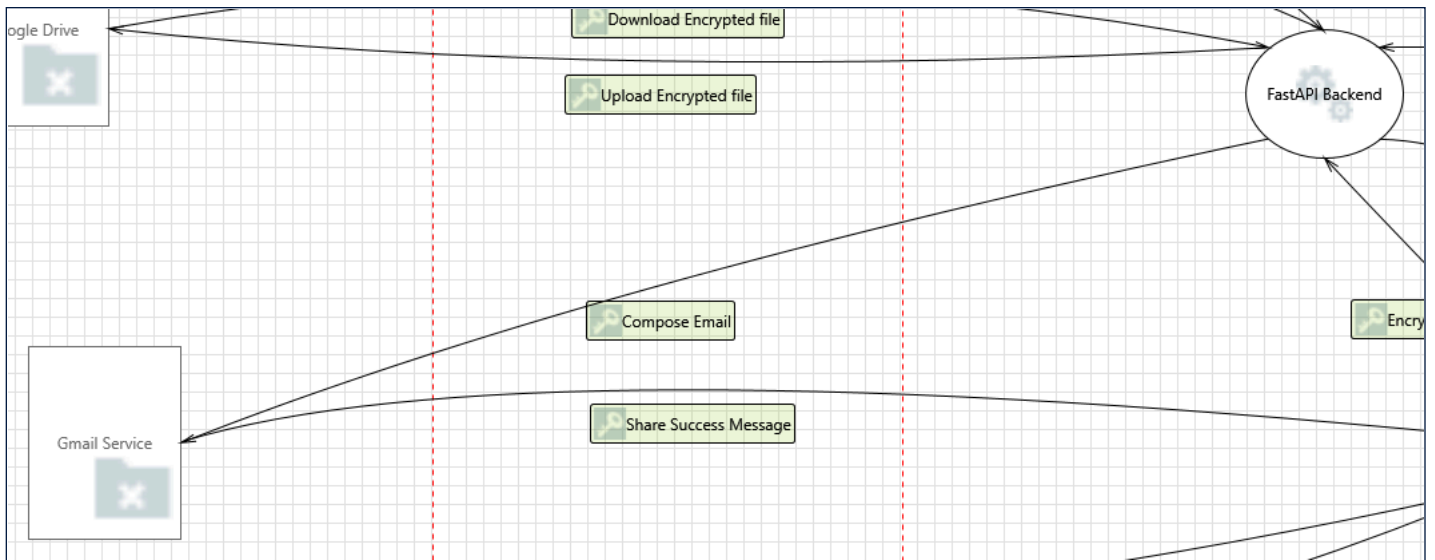
10. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: Medium]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: The ENCRYPTIX Web Frontend processes JSON-based authentication data received from the OAuth Provider and uses it to control application behavior. The use of HTTPS ensures secure transmission and integrity of data in transit, while CORS policies restrict which external sources can communicate with the frontend, reducing the risk of unauthorized data access. Additionally, Content Security Policy (CSP) significantly mitigates the risk of script injection and execution-based attacks. However, improper validation or unsafe handling of token data may still influence application logic or behavior. Therefore, the threat remains applicable but is strongly mitigated.

Interaction: Compose Email



11. Data Flow Compose Email Is Potentially Interrupted [State: Not Applicable] [Priority: Low]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The system redirects users (and not sends any user data) to the Gmail web interface over HTTPS, where communication is handled directly by the browser with Google's trusted domain. Since the application does not directly control or transmit data to the Gmail Service, and the communication occurs over a secure, externally managed channel, there is no opportunity for an external agent to interrupt data flow within the system context, making this threat not applicable.

12. External Entity Gmail Service Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: Medium]

Category: Repudiation

Description: Gmail Service claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The interaction with Gmail Service is performed over HTTPS using authenticated Google accounts, and Gmail provides built-in logging and traceability for email actions, including sent messages and activity history. These mechanisms allow verification of whether data was received and processed, thereby mitigating the risk of repudiation.

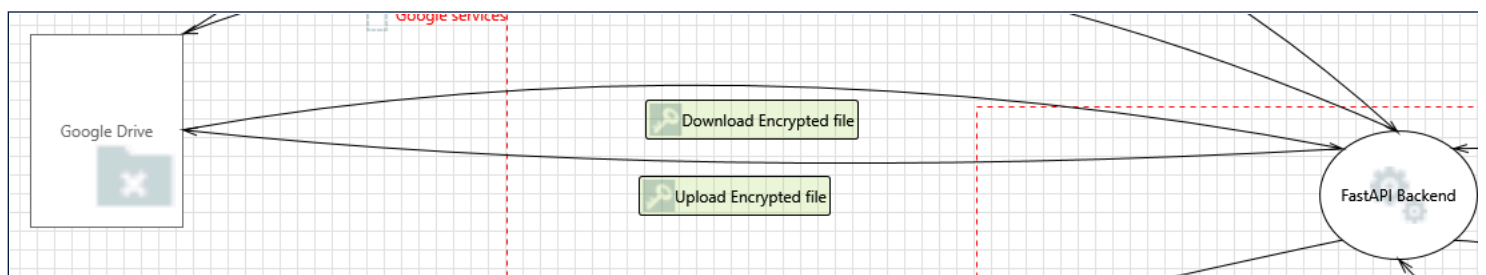
13. Spoofing of the Gmail Service External Destination Entity [State: Not Applicable] [Priority: Low]

Category: Spoofing

Description: Gmail Service may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Gmail Service. Consider using a standard authentication mechanism to identify the external entity.

Justification: The system redirects users to the Gmail web interface over HTTPS, where communication is handled directly by the browser with Google's trusted domain. The use of HTTPS ensures that the domain identity is verified and prevents redirection to malicious endpoints. Additionally, the Gmail service is accessed through Google's authenticated environment, and the application does not dynamically determine or control the destination service. Therefore, spoofing of the Gmail Service is not applicable.

Interaction: Download Encrypted file



14. Elevation by Changing the Execution Flow in FastAPI Backend [State: Mitigation Implemented] [Priority: Medium]

Category: Elevation Of Privilege

Description: An attacker may pass data into FastAPI Backend in order to change the flow of program execution within FastAPI Backend to the attacker's choosing.

Justification: The FastAPI Backend retrieves encrypted files from Google Drive and forwards them to the Web Frontend without performing complex processing such as decryption or parsing. Since the backend primarily handles file transfer with minimal interpretation of file content, the risk of attacker-controlled data influencing execution flow is reduced. However, basic input handling and request processing still exist, so the threat remains applicable but is mitigated. If needed following mitigations can be applied:

- Validate request parameters and file metadata
- Implement strong input validation for API endpoints
- Use streaming to minimize processing overhead

15. FastAPI Backend May be Subject to Elevation of Privilege Using Remote Code Execution [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: Google Drive may be able to remotely execute code for FastAPI Backend.

Justification: Google Drive acts as a passive data storage service that returns files to the FastAPI Backend over authenticated and secure API calls. It does not send executable instructions or control the execution logic of the backend. Since all processing and execution are performed within the FastAPI Backend, remote code execution by Google Drive is not applicable.

16. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: FastAPI Backend may be able to impersonate the context of Google Drive in order to gain additional privilege.

Justification: The FastAPI Backend interacts with Google Drive as a client using authenticated API requests over HTTPS. Google Drive operates as an independent external service with its own identity and authentication mechanisms, and the FastAPI Backend does not assume or reuse the identity or privileges of Google Drive. Therefore, impersonation of the Google Drive context is not applicable.

17. Data Flow Download Encrypted file Is Potentially Interrupted [State: Not Applicable] [Priority: Low]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The communication between FastAPI Backend and Google Drive occurs over secure HTTPS connections using authenticated API requests. This interaction is conducted through controlled service-to-service communication channels and does not expose a path for external agents to intercept or interrupt the data flow. Therefore, interruption by an external agent is not applicable.

18. Potential Process Crash or Stop for FastAPI Backend [State: Needs Investigation] [Priority: Medium]

Category: Denial Of Service

Description: FastAPI Backend crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: The FastAPI Backend downloads encrypted files from Google Drive and serves them to the Web Frontend for user download. Although file sizes are limited, the backend acts as an intermediary handling both incoming data from Google Drive and outgoing responses to clients. Concurrent download requests, network latency from Google Drive, or inefficient handling of streaming between backend and frontend can lead to increased resource usage or blocking operations. This may cause the backend to slow down, become unresponsive, or degrade in performance, impacting overall system availability.

Mitigations to be applied:

- Use asynchronous request handling in FastAPI
- Limit concurrent download requests
- Configure timeouts and retries for Google Drive API calls
- Monitor backend performance and connection handling

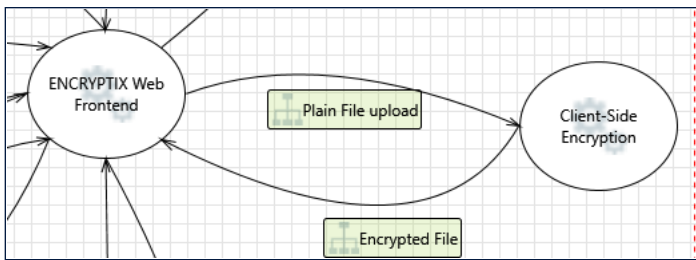
19. Potential Data Repudiation by FastAPI Backend [State: Not Applicable] [Priority: Medium]

Category: Repudiation

Description: FastAPI Backend claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The FastAPI Backend retrieves encrypted files from Google Drive over HTTPS using authenticated API calls. Google Drive, as a managed service, maintains access logs and request traceability, while OAuth-based authentication ensures that all interactions are associated with a verified identity. These mechanisms provide evidence of data transfer and receipt, thereby mitigating the risk of repudiation.

Interaction: Encrypted File



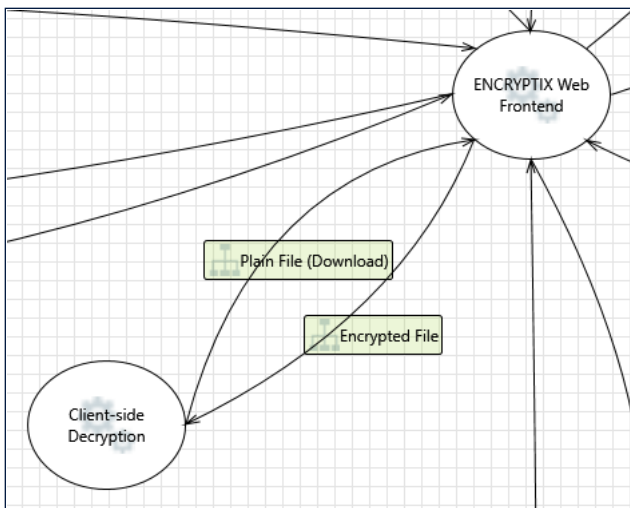
20. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: ENCRYPTITX Web Frontend may be able to impersonate the context of Client-Side Encryption in order to gain additional privilege.

Justification: Client-side encryption is implemented as part of the ENCRYPTITX Web Frontend within the same browser execution environment and does not exist as a separate component with an independent identity or privilege context. Since the frontend and the encryption logic operate within the same process and trust boundary, there is no distinct context to impersonate. Therefore, this elevation of privilege threat is not applicable.

Interaction: Encrypted File



21. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: Client-side Decryption may be able to impersonate the context of ENCRYPTITX Web Frontend in order to gain additional privilege.

Justification: Client-side decryption is implemented as part of the ENCRYPTITX Web Frontend within the same browser execution environment and does not exist as a separate component with an independent identity or privilege context. Since the frontend and the decryption logic operate within the same process and trust boundary, there is no distinct context to impersonate. Therefore, this elevation of privilege threat is not applicable.

22. Collision Attacks [State: Not Applicable] [Priority: Low]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: Client-Side Decryption receives the encrypted file directly within the browser and processes complete file data. The application does not implement custom packet fragmentation, packet reassembly, or low-level network message processing. Since no packet reassembly occurs in this interaction, overlapping-packet attacks are not applicable.

23. Replay Attacks [State: Not Applicable] [Priority: Low]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

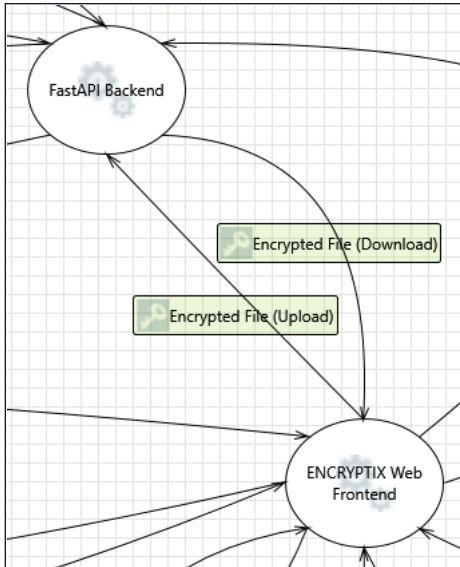
Justification: The interaction does not involve a network communication channel, message transport protocol, or independently transmitted packets. Since no external communication path exists from which messages can be captured and replayed, replay attacks are not applicable.

24. Weak Authentication Scheme [State: Not Applicable] [Priority: Medium]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: The transfer of the encrypted file from the Web Frontend to the Client-Side Decryption component does not involve an authentication mechanism. Client-side decryption simply receives the encrypted file and a user-provided decryption key for cryptographic processing within the browser. Since no custom authentication scheme, credential validation process, or identity verification mechanism exists in this interaction, this threat is not applicable.

Interaction: Encrypted File (Download)**25. Elevation Using Impersonation** [State: Mitigation Implemented] [Priority: Medium]

Category: Elevation Of Privilege

Description: ENCRYPTIX Web Frontend may be able to impersonate the context of FastAPI Backend in order to gain additional privilege.

Justification: The ENCRYPTIX Web Frontend communicates with the FastAPI Backend across a trust boundary, where the frontend is a user-controlled component. Although there is a risk that the frontend could attempt to impersonate a trusted backend context, the use of JWT-based authentication ensures that all requests are validated, and identities are verified based on signed tokens. This prevents unauthorized entities from forging trusted identities or gaining additional privileges. Therefore, the threat is mitigated.

26. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: Medium]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: The encrypted file download flow uses JWT-based authentication rather than a proprietary authentication mechanism. The backend validates authenticated requests before providing access to encrypted files. Since a standard token-based authentication mechanism is used instead of a custom authentication scheme, the risk associated with weak custom authentication is mitigate

27. Replay Attacks [State: Mitigation Implemented] [Priority: Medium]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: The encrypted file is transferred from the FastAPI Backend to the Web Frontend over HTTPS. JWT authentication validates the requesting user, and HTTPS provides integrity protection during transmission. Since the flow involves file retrieval rather than execution of state-changing commands, the impact of message replay is limited. Therefore, the threat is mitigated.

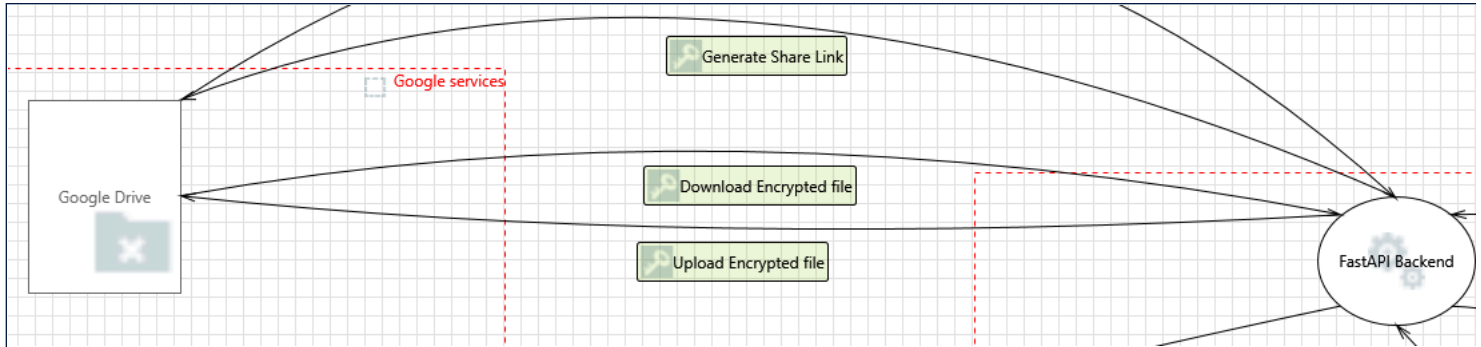
28. Collision Attacks [State: Not Applicable] [Priority: Low]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: The encrypted file download is performed using standard HTTPS communication. Packet fragmentation and reassembly are handled by the underlying TCP/TLS stack before data reaches the application. The application does not perform custom packet reassembly or low-level network message processing. Therefore, overlapping-packet attacks are not applicable.

Interaction: Generate Share Link



29. Data Flow Generate Share Link Is Potentially Interrupted [State: Not Applicable] [Priority: Medium]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The FastAPI Backend communicates with Google Drive using authenticated API requests over HTTPS through predefined and trusted endpoints. This interaction occurs via controlled service-to-service communication and does not expose a path for external agents to intercept or interrupt the data flow. Therefore, interruption by an external agent is not applicable. But DOS due system failures still may occur.

30. External Entity Google Drive Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: Medium]

Category: Repudiation

Description: Google Drive claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The FastAPI Backend communicates with Google Drive using authenticated API requests over HTTPS. Google Drive, as a managed service, maintains logs of API interactions and associates requests with authenticated identities through OAuth. These mechanisms provide traceability of operations and verification of request handling, thereby mitigating the risk of repudiation.

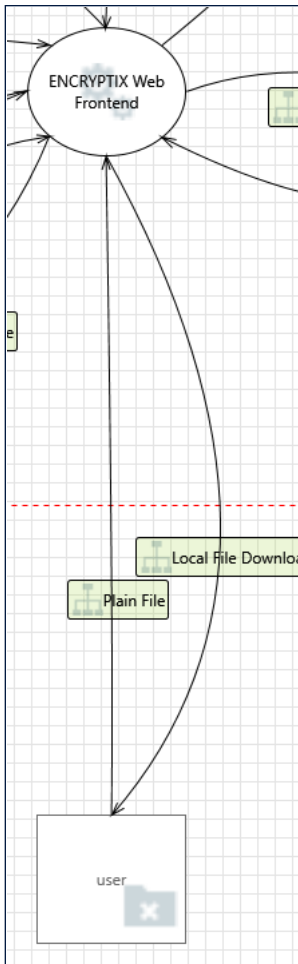
31. Spoofing of the Google Drive External Destination Entity [State: Not Applicable] [Priority: Low]

Category: Spoofing

Description: Google Drive may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Google Drive. Consider using a standard authentication mechanism to identify the external entity.

Justification: The FastAPI Backend interacts with Google Drive through predefined API endpoints over HTTPS using OAuth-based authentication.

Interaction: Local File Download



32. Data Flow Local File Download Is Potentially Interrupted [State: Not Applicable] [Priority: Low]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The decryption and file download processes occur entirely within the browser as part of the frontend execution environment, without crossing a trust boundary or involving multiple independent components. Since there is no external communication or interaction with another entity during this stage, there is no opportunity for an external agent to interrupt the data flow. Therefore, this threat is not applicable.

33. External Entity user Potentially Denies Receiving Data [State: Not Applicable] [Priority: Low]

Category: Repudiation

Description: user claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The decryption and file download occur entirely within the browser as part of the frontend execution environment, without involving separate components or crossing a trust boundary. Since there is no independent entity receiving data from another system component, there is no distinct interaction that can be denied or audited. Therefore, repudiation is not applicable in this context.

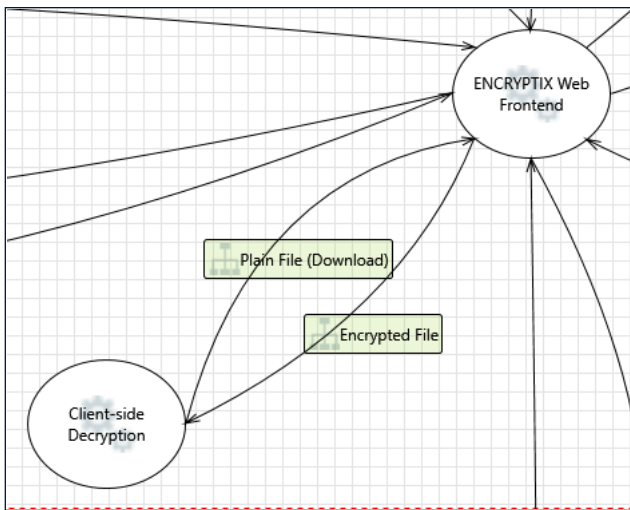
34. Spoofing of the user External Destination Entity [State: Not Applicable] [Priority: Low]

Category: Spoofing

Description: user may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of user. Consider using a standard authentication mechanism to identify the external entity.

Justification: The decrypted file download occurs within the user's browser environment and is delivered directly to the same client that initiated the request. There is no dynamic selection of a destination or separate external entity involved in the transfer. Since the system does not route data between different users or identities, there is no opportunity for an attacker to impersonate a user and redirect the file to another target. Therefore, spoofing of the user is not applicable.

Interaction: Plain File (Download)



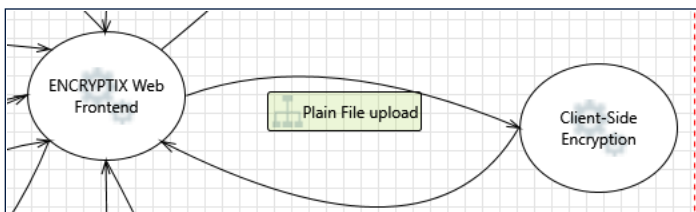
35. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: ENCRYPTIX Web Frontend may be able to impersonate the context of Client-side Decryption in order to gain additional privilege.

Justification: Client-side decryption is implemented as part of the ENCRYPTIX Web Frontend within the same browser execution environment and does not exist as a separate component with an independent identity or privilege context. Since the frontend and the encryption logic operate within the same process and trust boundary, there is no distinct context to impersonate. Therefore, this elevation of privilege threat is not applicable.

Interaction: Plain File upload



36. Collision Attacks [State: Not Applicable] [Priority: Low]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0. Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: The plain file is passed directly from the Web Frontend to the Client-Side Encryption component within the browser execution environment. The application does not perform custom packet fragmentation, packet transmission, or packet reassembly. Since complete file data is processed locally without low-level network packet handling, overlapping-packet attacks are not applicable.

37. Replay Attacks [State: Not Applicable] [Priority: Low]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: The interaction does not involve a network communication channel, message transport protocol, or independently transmitted packets. Since no external communication path exists from which messages can be captured and replayed, replay attacks are not applicable.

38. Weak Authentication Scheme [State: Not Applicable] [Priority: Low]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: The file upload from the Web Frontend to the Client-Side Encryption component does not involve user authentication, identity verification, credential validation, or a custom authentication mechanism. The interaction only transfers a user-selected file for local encryption processing within the browser. Therefore, this threat is not applicable.

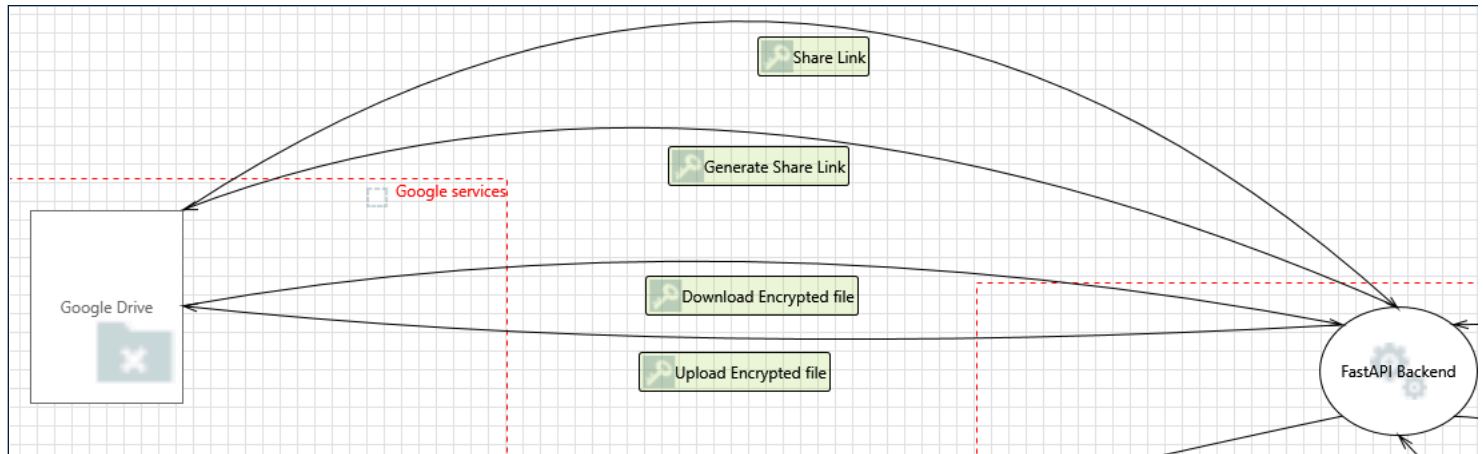
39. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: Client-Side Encryption may be able to impersonate the context of ENCRYPTIX Web Frontend in order to gain additional privilege.

Justification: Client-side encryption is implemented as part of the ENCRYPTIX Web Frontend within the same browser execution environment and does not exist as a separate component with an independent identity or privilege context. Since the frontend and the encryption logic operate within the same process and trust boundary, there is no distinct context to impersonate. Therefore, this elevation of privilege threat is not applicable.

Interaction: Share Link



40. Potential Process Crash or Stop for FastAPI Backend [State: Mitigation Implemented] [Priority: High]

Category: Denial Of Service

Description: FastAPI Backend crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: The FastAPI Backend retrieves only a share link from Google Drive rather than downloading or processing large files. Since the operation involves a lightweight API call with minimal resource consumption, the likelihood of significant performance degradation is reduced. However, the backend still depends on external API availability and network responsiveness. But we can configure request timeouts, implement retry handling for transient failures and handle Google API errors gracefully.

41. Potential Data Repudiation by FastAPI Backend [State: Mitigation Implemented] [Priority: Medium]

Category: Repudiation

Description: FastAPI Backend claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The FastAPI Backend retrieves the share link from Google Drive using authenticated API requests over HTTPS. Google APIs maintain request traceability and activity logs, and the interaction is associated with an authenticated identity through OAuth. These mechanisms provide evidence of data transfer and receipt, reducing the likelihood of repudiation.

42. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: Medium]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: Communication between Google Drive and the FastAPI Backend uses standard Google REST APIs that exchange structured JSON data over HTTPS. The backend consumes authenticated API responses and does not expose raw JSON directly to browsers for execution. But still validating JSON schema can help further.

43. Data Flow Share Link Is Potentially Interrupted [State: Not Applicable] [Priority: Medium]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The FastAPI Backend communicates with Google Drive using authenticated API requests over HTTPS through predefined and trusted endpoints. This interaction occurs via controlled service-to-service communication and does not expose a path for external agents to intercept or interrupt the data flow. Therefore, interruption by an external agent is not applicable. But DOS due to system failures still may occur.

44. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: FastAPI Backend may be able to impersonate the context of Google Drive in order to gain additional privilege.

Justification: The FastAPI Backend interacts with Google Drive as a client using authenticated Google Drive APIs. Google Drive operates as an independent external service with its own identity, permissions, and authentication mechanisms.

45. FastAPI Backend May be Subject to Elevation of Privilege Using Remote Code Execution [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: Google Drive may be able to remotely execute code for FastAPI Backend.

Justification: Google Drive acts as a storage service and returns share-link information through authenticated API responses. The FastAPI Backend retrieves and processes this data but does not execute instructions received from Google Drive.

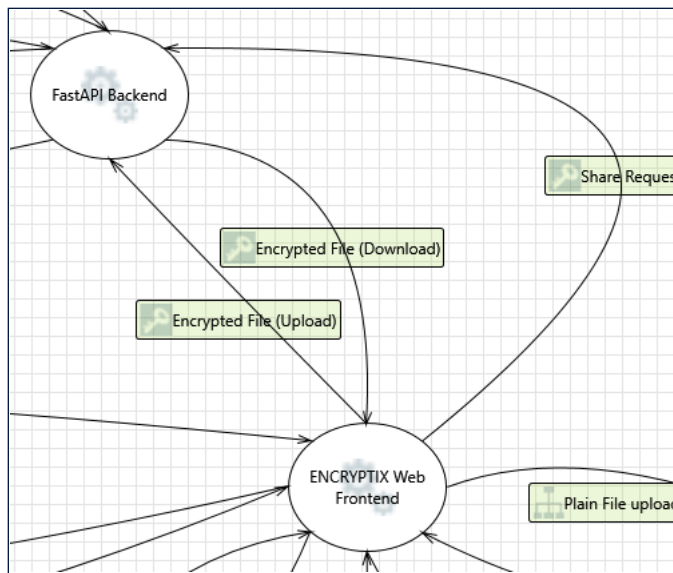
46. Elevation by Changing the Execution Flow in FastAPI Backend [State: Mitigation Implemented] [Priority: Medium]

Category: Elevation Of Privilege

Description: An attacker may pass data into FastAPI Backend in order to change the flow of program execution within FastAPI Backend to the attacker's choosing.

Justification: The FastAPI Backend receives only share-link metadata from Google Drive through authenticated Google Drive APIs over HTTPS. The response format is controlled by Google's API and is not arbitrary user-supplied input. Additionally, the backend processes the returned data as API response data rather than executable instructions.

Interaction: Share Request



47. JavaScript Object Notation Processing [State: Mitigation Implemented] [Priority: Medium]

Category: Tampering

Description: If a dataflow contains JSON, JSON processing and hijacking threats may be exploited.

Justification: The share request is transmitted as structured JSON data between the Web Frontend and FastAPI Backend over HTTPS. The JSON data is processed server-side by the FastAPI Backend and is not exposed as executable content in a browser context.

48. Collision Attacks [State: Not Applicable] [Priority: Low]

Category: Tampering

Description: Attackers who can send a series of packets or messages may be able to overlap data. For example, packet 1 may be 100 bytes starting at offset 0.

Packet 2 may be 100 bytes starting at offset 25. Packet 2 will overwrite 75 bytes of packet 1. Ensure you reassemble data before filtering it, and ensure you explicitly handle these sorts of cases.

Justification: The transmissions are done using HTTPS/TLS

49. Replay Attacks [State: Mitigation Implemented] [Priority: High]

Category: Tampering

Description: Packets or messages without sequence numbers or timestamps can be captured and replayed in a wide variety of ways. Implement or utilize an existing communication protocol that supports anti-replay techniques (investigate sequence numbers before timers) and strong integrity.

Justification: The share request is transmitted from the Web Frontend to the FastAPI Backend over HTTPS and is authenticated using JWT tokens. HTTPS provides integrity protection for data in transit, while JWT validation ensures that requests originate from authenticated users. Additionally, the operation represents a controlled application request rather than a low-level message protocol. Therefore, the replay threat is mitigated.

50. Weak Authentication Scheme [State: Mitigation Implemented] [Priority: Medium]

Category: Information Disclosure

Description: Custom authentication schemes are susceptible to common weaknesses such as weak credential change management, credential equivalence, easily guessable credentials, null credentials, downgrade authentication or a weak credential change management system. Consider the impact and potential mitigations for your custom authentication scheme.

Justification: The share request flow uses JWT-based authentication rather than a custom authentication mechanism. The FastAPI Backend validates the JWT before processing the request, ensuring that authentication is handled through a standard token-based approach.

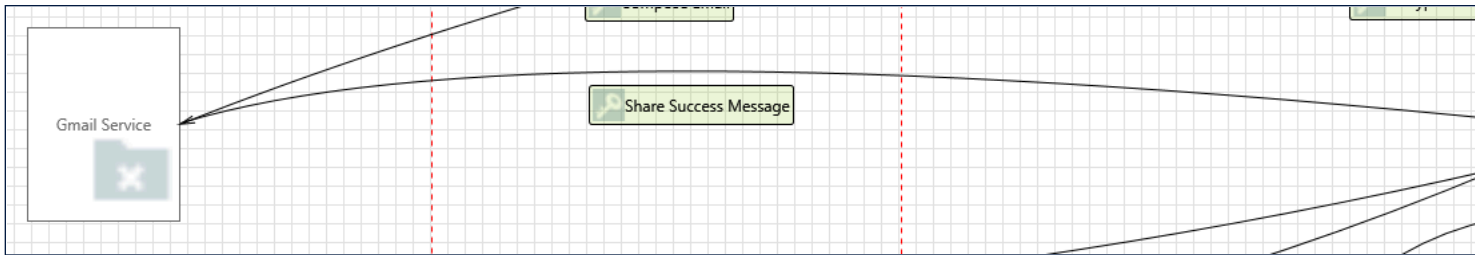
51. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: FastAPI Backend may be able to impersonate the context of ENCRYPTIX Web Frontend in order to gain additional privilege.

Justification: The FastAPI Backend and ENCRYPTIX Web Frontend are separate components with distinct roles and privilege levels. The FastAPI Backend acts as the server-side component that processes requests from the frontend and already operates with its own service identity and permissions. Since the backend does not gain additional privileges by pretending to be the frontend, impersonation of the frontend context does not result in elevation of privilege.

Interaction: Share Success Message



52. Potential Data Repudiation by ENCRYPTIX Web Frontend [State: Mitigation Implemented] [Priority: High]

Category: Repudiation

Description: ENCRYPTIX Web Frontend claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The Web Frontend receives the share status from Gmail after the user initiates the sharing operation. The status is visible to the user through the Gmail interface and is associated with a user-initiated action. The interaction is traceable through Gmail and frontend activity, reducing the likelihood of repudiation. But still keeping logs of the site is a good practice.

53. Potential Process Crash or Stop for ENCRYPTIX Web Frontend [State: Not Applicable] [Priority: Low]

Category: Denial Of Service

Description: ENCRYPTIX Web Frontend crashes, halts, stops or runs slowly; in all cases violating an availability metric.

Justification: The flow only involves receiving a lightweight success or status message from Gmail. No file processing, cryptographic operation, or resource-intensive action occurs as part of this interaction.

54. Data Flow Share Success Message Is Potentially Interrupted [State: Not Applicable] [Priority: Low]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The interaction consists of a lightweight status or success message returned from the Gmail service to the Web Frontend following a user-initiated sharing operation. The flow does not involve continuous communication, large data transfer, or critical business processing. Therefore, interruption of this status message does not present a significant availability risk.

55. Elevation Using Impersonation [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: ENCRYPTIX Web Frontend may be able to impersonate the context of Gmail Service in order to gain additional privilege.

Justification: The Web Frontend and Gmail Service are separate components with distinct identities and responsibilities. The Web Frontend does not assume Gmail's identity, permissions, or privileges and only receives a status response from Gmail.

56. ENCRYPTIX Web Frontend May be Subject to Elevation of Privilege Using Remote Code Execution [State: Not Applicable] [Priority: Low]

Category: Elevation Of Privilege

Description: Gmail Service may be able to remotely execute code for ENCRYPTIX Web Frontend.

Justification: The Web Frontend and Gmail Service are separate components with distinct identities and responsibilities. The Web Frontend does not assume Gmail's identity, permissions, or privileges and only receives a status response from Gmail.

57. Elevation by Changing the Execution Flow in ENCRYPTIX Web Frontend [State: Mitigation Implemented] [Priority: Medium]

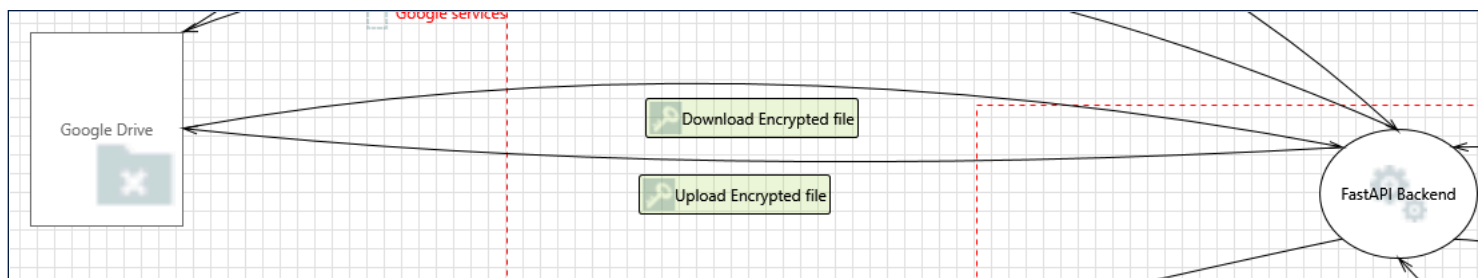
Category: Elevation Of Privilege

Description: An attacker may pass data into ENCRYPTIX Web Frontend in order to change the flow of program execution within ENCRYPTIX Web Frontend to the attacker's choosing.

Justification: The ENCRYPTIX Web Frontend receives a predefined status or success response from the Gmail service after a sharing operation. The response is processed as application data and does not contain executable code. Still good practices like :

- Validate and sanitize all response data before use.
 - Treat external data as untrusted input.
 - Avoid dynamic code execution based on response content.
 - Implement secure input handling and error handling.
- can be implemented.

Interaction: Upload Encrypted file



58. Data Flow Upload Encrypted file Is Potentially Interrupted [State: Not Applicable] [Priority: Medium]

Category: Denial Of Service

Description: An external agent interrupts data flowing across a trust boundary in either direction.

Justification: The FastAPI Backend communicates with Google Drive using authenticated API requests over HTTPS through predefined Google endpoints. This interaction occurs via controlled service-to-service communication and does not expose a path for external agents to intercept or interrupt the data flow. Any failures would more likely result from network issues or service availability problems rather than interruption by an external attacker. Therefore, this threat is not applicable.

59. External Entity Google Drive Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: Medium]

Category: Repudiation

Description: Google Drive claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.

Justification: The FastAPI Backend communicates with Google Drive using authenticated API requests over HTTPS. Google Drive, as a managed service, maintains logs of API interactions and associates requests with authenticated identities through OAuth. These mechanisms provide traceability of operations and verification of request handling, thereby mitigating the risk of repudiation.

60. Spoofing of the Google Drive External Destination Entity [State: Not Applicable] [Priority: Low]

Category: Spoofing

Description: Google Drive may be spoofed by an attacker and this may lead to data being sent to the attacker's target instead of Google Drive. Consider using a standard authentication mechanism to identify the external entity.

Justification: The FastAPI Backend interacts with Google Drive through predefined API endpoints over HTTPS using OAuth-based authentication. Hence spoofing is not possible.